

Actividad 5: Cartografiando el pentesting: análisis corporativo de metodologías de seguridad informática

CNOV SEGURIDAD INFORMATICA
Profesor: Servando López Contreras

Carrera: ITI

Alumno:

Enrique Alvarez Aquino – 177071

	MITRE ATT&CK	OWASP WSTG	NIST SP 800-115	OSSTMM	PTES	ISSAF
Descripción técnica	Base de conocimiento que modela el comportamiento real de adversarios mediante tácticas y técnicas post-explotación usadas en ataques reales. No es una guía de pentesting sino de detección.	Metodología de pruebas para aplicaciones web enfocada en vulnerabilidades más comunes.	Guía gubernamental para evaluación técnica de controles de seguridad en organizaciones.	Metodología científica que mide seguridad mediante métricas verificables (RAV score).	Estándar profesional de ejecución de pentesting completo desde contrato hasta reporte.	Framework detallado para auditorías técnicas con procedimientos paso a paso.
Fases	Reconocimiento Acceso inicial Ejecución Persistencia Escalada privilegios Movimiento lateral Exfiltración	Información Configuración Autenticación Autorización Validación Lógica negocio	Planeación Descubrimiento Ataque controlado Reporte	Inducción Interacción Investigación Intervención	Pre-engagement Inteligencia Modelado amenazas Explotación Post-explotación Reporte	Planeación Evaluación Explotación Reporte
Objetivo principal	Detectar y mapear ataques reales	Encontrar vulnerabilidades web	Verificar eficacia de controles	Medir nivel real de seguridad	Simular ataque real completo	Auditoría de seguridad integral
Escenarios	SOC, monitoreo SIEM, respuesta a incidentes	Aplicaciones web, APIs, e-commerce	Auditorías empresariales y cumplimiento	Infraestructura crítica, telecomunicaciones	Pentesting corporativo	Auditorías internas/externas

Orientación	Defensa	Ataque	Evaluación	Evaluación	Ataque	Evaluación/Ataque
Autor	MITRE Corporation	OWASP Foundation	National Institute of Standards and Technology	ISECOM	PTES Technical Guidelines	OISSG
URL	https://attack.mitre.org	https://owasp.org/www-project-web-security-testing-guide	https://www.nist.gov/privacy-framework/nist-sp-800-115	https://www.isecom.org/OSSTMM.3.pdf	http://www.pentest-standard.org	https://www.oissg.org/iissaf
Certificaciones	MITRE ATT&CK Defender	OSWE, CEH	CISSP, CISA	OPST, OPSA	OSCP, PNPT, eJPT	CEH, CHFI
Vigencia	V16 – actualizada continuamente	WSTG v4 vigente	SP 800-115 vigente como guía	OSSTMM 3 vigente	V1.1 estándar	V0.2.1 considerado histórico

Conclusión:

Las metodologías analizadas no compiten entre sí, sino que se complementan dentro de un programa de ciberseguridad. El pentesting proporciona evidencia práctica de vulnerabilidades, mientras que los marcos de evaluación validan controles y los modelos de ataque permiten detectar amenazas reales.

Por ello, el profesional de seguridad informática debe seleccionar la metodología adecuada dependiendo del contexto: auditoría, simulación de ataque o monitoreo defensivo.

Referencias:

Cisco Networking Academy. (2026). *Ethical Hacker*. Cisco Systems.

<https://www.netacad.com/>

MITRE Corporation. (2024). *MITRE ATT&CK framework*.

<https://attack.mitre.org/>

Open Web Application Security Project (OWASP). (2023). *Web Security Testing Guide (WSTG)*.

<https://owasp.org/www-project-web-security-testing-guide/>

National Institute of Standards and Technology. (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.

<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf>

ISECOM. (2010). *Open Source Security Testing Methodology Manual (OSSTMM 3)*.

<https://www.isecom.org/OSSTMM.3.pdf>

Penetration Testing Execution Standard. (2022). *PTES Technical Guidelines*.

<http://www.pentest-standard.org/>

Open Information Systems Security Group. (2021). *Information Systems Security Assessment Framework (ISSAF)*.

<https://www.oissg.org/issaf>